

Encuesta STRIDE de Madurez y Métricas de Ciberseguridad

Aplicación a organizaciones españolas bajo NIS2 / ENS / marcos sectoriales

Esta encuesta pretende medir, con cierto rigor y sin perder el sentido del humor, cómo gestionan ustedes las seis maneras clásicas de romper un sistema: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service y Elevation of Privilege.

No se puntúa la perfección; se puntúa la honestidad informada.

0. Datos generales de la organización

0.1. Sector principal de actividad

Seleccione el sector que mejor represente la actividad regulada de su organización:

- ☐ Administración pública (AGE, CCAA, EELL)
- ☐ Sanidad (pública o privada con servicios esenciales)
- ☐ Energía y utilities
- ☐ Transporte y logística
- ☐ Finanzas y seguros
- ☐ Telecomunicaciones / servicios digitales esenciales
- ☐ Industria / manufactura
- ☐ Educación / investigación
- ☐ Otros (especificar): _____

0.2. Tamaño aproximado de la organización (empleados)

- ☐ < 250
- ☐ 250–999
- ☐ 1.000–4.999
- ☐ 5.000–19.999
- ☐ ≥ 20.000

0.3. ¿Está sujeta la organización a NIS2 como entidad esencial o importante?

- ☐ Esencial
- ☐ Importante
- ☐ No aplica / No lo tenemos claro, pero intuimos que no será barato

0.4. Marcos de referencia adoptados (marque todos los que apliquen)

- ☐ ENS (Esquema Nacional de Seguridad)
- ☐ ISO/IEC 27001
- ☐ NIST CSF (versión 1.1 / 2.0)
- ☐ DORA (sector financiero)
- ☐ AI Act / ISO/IEC 42001 (sistemas de IA)
- ☐ Otros (especificar): _____

1. Gobierno y proceso de threat modeling

1.1. ¿Existe un proceso formal de threat modeling reconocido por la dirección?

- ☐ Sí, formalmente definido, documentado y aprobado
- ☐ Parcialmente: existe, pero no está formalizado ni aprobado
- ☐ Informal: depende de la buena voluntad de equipos concretos
- ☐ No existe / No nos consta

1.2. En su organización, ¿con qué frecuencia se realiza threat modeling en proyectos relevantes?

- ☐ En todos los proyectos críticos antes de entrar en producción
- ☐ Solo en proyectos “importantes” seleccionados caso a caso
- ☐ Solo cuando lo exige un auditor / regulador / incidente
- ☐ Rara vez o nunca

1.3. ¿Se utiliza explícitamente STRIDE como marco en el threat modeling?

- ☐ Sí, de forma obligatoria para sistemas y servicios críticos
- ☐ Sí, pero solo como referencia orientativa
- ☐ No STRIDE, usamos otros marcos (PASTA, OCTAVE, etc.)
- ☐ No se utiliza ningún marco identificable

1.4. ¿Quién participa habitualmente en las sesiones de threat modeling? (marque todos los que apliquen)

- ☐ CISO / responsable de seguridad
- ☐ Arquitectura de TI / Arquitectura empresarial
- ☐ Desarrollo / DevSecOps
- ☐ Operaciones / Infraestructuras
- ☐ Responsable de negocio / propietario del servicio
- ☐ Jurídico / cumplimiento
- ☐ Proveedores / terceros clave
- ☐ Otros: _____

1.5. ¿Se mantiene un inventario centralizado de amenazas identificadas, clasificado por STRIDE, reutilizable por toda la organización?

- ☐ Sí, con taxonomía STRIDE y actualización regular
- ☐ Parcialmente, pero no está normalizado ni se reutiliza de forma sistemática
- ☐ Solo como anexos dispersos en proyectos / auditorías
- ☐ No existe un inventario centralizado de amenazas

2. Spoofing (Suplantación de identidad)

2.1. Cobertura de autenticación multifactor (MFA) en accesos críticos

Para los sistemas y servicios críticos identificados (según ENS, NIS2 u otro marco), ¿qué nivel de cobertura de MFA estima que tiene actualmente?

- ☐ ≥ 90 % de accesos críticos protegidos con MFA
- ☐ Entre 60 % y 89 %
- ☐ Entre 30 % y 59 %
- ☐ < 30 %
- ☐ No lo medimos / No aplicamos MFA de forma sistemática

2.2. Protección de accesos privilegiados (PAM / MFA reforzada)

Las cuentas con privilegios elevados (administradores de dominio, root, DBA, etc.):

- ☐ Se gestionan a través de una solución PAM dedicada con MFA obligatorio
- ☐ Tienen MFA, pero sin solución PAM específica
- ☐ Mezcla heterogénea: algunas con MFA/PAM, otras no
- ☐ No disponen de medidas específicas más allá de usuario/contraseña

2.3. Autenticación en APIs y servicios machine-to-machine

- ☐ La totalidad de las APIs críticas utilizan autenticación fuerte (tokens firmados, mutual TLS, etc.)
- ☐ La mayoría de las APIs críticas tienen autenticación fuerte; existen excepciones heredadas
- ☐ Algunas APIs críticas siguen utilizando esquemas débiles (API keys simples, basic auth, etc.)
- ☐ No existe un inventario claro de APIs críticas ni de sus mecanismos de autenticación

2.4. Detección y métricas de intentos de suplantación

- ☐ Disponemos de métricas consolidadas (intentos de login sospechosos, uso de credenciales robadas, etc.) revisadas al menos mensualmente
- ☐ Se monitorizan intentos de suplantación, pero sin métricas ni revisión periódica
- ☐ Solo se investigan casos concretos tras un incidente
- ☐ No se realiza monitorización específica de suplantación

2.5. Identidad digital de máquinas y servicios

- ☐ Existe una PKI bien gobernada para certificados de servidor, cliente y dispositivos
- ☐ La PKI existe, pero con gobernanza parcial o inventario incompleto
- ☐ Se utilizan certificados dispersos sin política clara
- ☐ No se utiliza PKI propia ni inventario formal de identidades técnicas

3. Tampering (Manipulación de datos y sistemas)

3.1. Protección de integridad de registros y datos críticos

- ☐ Los datos y logs críticos se almacenan con mecanismos de integridad criptográfica (hashes encadenados, WORM, etc.) y se audita su uso
- ☐ Existen mecanismos de integridad en algunos sistemas, pero no es una práctica generalizada
- ☐ Se confía en la integridad del sistema de ficheros o base de datos sin medidas criptográficas específicas
- ☐ No se aplican controles específicos de integridad más allá de los estándar del sistema

3.2. Capacidad de personal interno para modificar datos de negocio sin trazabilidad

- ☐ Los procesos críticos requieren doble control o segregación de funciones, y toda modificación queda registrada
- ☐ En la mayoría de los casos hay trazabilidad, pero existen “atajos” o accesos directos en determinados sistemas
- ☐ Hay perfiles con capacidad amplia de modificación directa, sin trazabilidad suficiente
- ☐ No se ha analizado explícitamente esta cuestión

3.3. Integridad en dispositivos IoT/OT (si aplica)

- ☐ Todos los dispositivos críticos cuentan con firmware firmado, arranque seguro y actualizaciones controladas
- ☐ Una parte significativa de dispositivos cumple, pero coexisten dispositivos sin esas capacidades
- ☐ Mayoritariamente no se dispone de estas garantías; se confía en el proveedor y la red
- ☐ No aplica (no operamos dispositivos IoT/OT relevantes)

3.4. Control de cambios de configuración

- ☐ Existe gestión de cambios formal, con revisión, aprobación, registro y, cuando procede, control doble para sistemas críticos
- ☐ Hay gestión de cambios, pero limitada o parcial según equipos
- ☐ Los cambios se realizan principalmente ad hoc y la documentación es irregular
- ☐ No existe un proceso reconocible de gestión de cambios

4. Repudiation (No repudio y trazabilidad)

4.1. Cobertura de logging en sistemas críticos

- ☐ Todos los sistemas críticos tienen logging detallado activado, centralizado en SIEM y revisado regularmente
- ☐ La mayoría de sistemas críticos están integrados en logging centralizado, con algunas lagunas
- ☐ Existen sistemas críticos sin logging suficiente o sin integración central
- ☐ No existe estrategia central de logging

4.2. Logs inmutables y retención

- ☐ Parte relevante de los logs se almacena en formato inmutable (WORM, almacenamiento con retención legal) con retención acordada con legal/compliance
- ☐ Hay logs inmutables solo para ámbitos concretos (financiero, salud, etc.)
- ☐ Los logs se conservan en sistemas estándar sin garantías de inmutabilidad
- ☐ No se dispone de política de retención ni de inmutabilidad clara

4.3. Capacidad de reconstrucción de eventos de seguridad

- ☐ Se han realizado pruebas periódicas para reconstruir incidentes utilizando logs, con resultados satisfactorios
- ☐ Se han realizado pruebas puntuales o simulaciones
- ☐ Solo se reconstruyen eventos cuando ocurre un incidente real
- ☐ No se ha intentado reconstruir eventos sistemáticamente

4.4. Trazabilidad en flujos que incluyen IA / automatización avanzada

- ☐ Todas las acciones generadas o asistidas por IA quedan claramente etiquetadas, trazadas y auditables
- ☐ Parcialmente: algunos sistemas de IA tienen trazabilidad, otros no
- ☐ No existe distinción clara entre acciones humanas y automatizadas en los registros
- ☐ No utilizamos IA de forma relevante (o eso nos gusta pensar)

5. Information Disclosure (Divulgación de información)

5.1. Inventario y clasificación de datos sensibles

- ☐ Existe un inventario actualizado de activos de información con clasificación (p.ej. pública, interna, confidencial, secreta)
- ☐ Existe clasificación, pero el inventario está incompleto o desactualizado
- ☐ La clasificación se aplica solo a algunos sistemas o proyectos
- ☐ No existe un esquema formal de clasificación de la información

5.2. Cifrado en reposo de datos sensibles

- ☐ Todos los datos sensibles se cifran en reposo con claves gestionadas y segregadas adecuadamente
- ☐ La mayoría de datos sensibles están cifrados, pero existen excepciones heredadas o temporales
- ☐ El cifrado en reposo se usa de forma parcial o ad hoc
- ☐ No se emplea cifrado en reposo de forma sistemática

5.3. Cifrado en tránsito y políticas de TLS

- ☐ Todo el tráfico hacia/desde servicios críticos se cifra con TLS configurado según buenas prácticas actuales
- ☐ La mayor parte del tráfico está protegido; se identifican algunos “rincones oscuros”
- ☐ Existen aún servicios críticos accesibles sin cifrado robusto
- ☐ No se ha realizado un análisis sistemático de cifrado en tránsito

5.4. Riesgo en integraciones con terceros y cloud

- ☐ Todas las integraciones críticas (APIs, SaaS, proveedores cloud) pasan por una evaluación formal de riesgo y contractual
- ☐ Solo las integraciones más visibles pasan por un proceso formal
- ☐ Los equipos negocian integraciones directamente sin evaluación de riesgo estructurada
- ☐ No hay visibilidad clara sobre el conjunto de integraciones externas existentes

5.5. Control de fugas en salidas de IA / analítica avanzada

- ☐ Se revisa y controla el riesgo de fuga de datos en salidas de modelos (LLM, analítica, etc.), con mecanismos técnicos y procesos
- ☐ Se ha considerado el riesgo, pero sin medidas sistemáticas
- ☐ No se ha analizado este riesgo
- ☐ No aplicable (no utilizamos este tipo de capacidades)

6. Denial of Service (DoS y resiliencia)

6.1. Medición de disponibilidad de servicios críticos

- ☐ Se miden y reportan SLA de disponibilidad para todos los servicios críticos, con datos históricos de al menos 12 meses
- ☐ Se miden SLA para algunos servicios, pero no para todos
- ☐ La disponibilidad se conoce de forma aproximada o se infiere de que “no ha habido muchas quejas”
- ☐ No se mide formalmente la disponibilidad

6.2. Protección frente a DoS/DDoS

- ☐ Los servicios externos críticos cuentan con protección específica (DDoS, WAF, CDN, etc.) y pruebas periódicas
- ☐ Existen medidas técnicas, pero sin pruebas ni revisión regular
- ☐ Solo algunos servicios disponen de tales protecciones
- ☐ No se han considerado medidas específicas frente a DoS/DDoS

6.3. Continuidad de negocio y planes de contingencia

- ☐ Hay planes de continuidad y recuperación probados regularmente para todos los servicios esenciales
- ☐ Existen planes, pero las pruebas son limitadas o esporádicas
- ☐ Los planes son principalmente documentos de buena voluntad no probados
- ☐ No existen planes formales de continuidad ni recuperación

6.4. Resiliencia de capacidades de seguridad (SOC, SIEM, etc.) ante DoS

- ☐ Se ha modelado y probado el impacto de un DoS sobre las propias herramientas de seguridad y hay planes de contingencia
- ☐ La cuestión se ha considerado, pero no se ha probado
- ☐ No se ha analizado el riesgo de pérdida de visibilidad de seguridad
- ☐ No disponemos de capacidades de monitorización centralizadas

7. Elevation of Privilege (Escalada de privilegios)

7.1. Gestión de identidades privilegiadas (PAM)

- ☐ Existe una solución de PAM en producción, con uso obligatorio para cuentas privilegiadas
- ☐ Hay PAM, pero su uso no es aún universal ni obligatorio
- ☐ No hay PAM, pero se aplican controles manuales (listas, procedimientos, etc.)
- ☐ No existe gestión diferenciada de identidades privilegiadas

7.2. Principio de mínimo privilegio

- ☐ Se aplica sistemáticamente (roles bien definidos, revisiones periódicas de permisos)
- ☐ Se aplica en algunas áreas, pero no es una práctica uniforme
- ☐ Se aplica de forma puntual y reactiva
- ☐ No se ha implantado de forma consciente

7.3. Auditoría de permisos y cuentas privilegiadas

- ☐ Se revisan permisos y cuentas privilegiadas al menos una vez al año, con acciones documentadas
- ☐ Las revisiones son esporádicas o dependen de auditorías externas
- ☐ Solo se revisan permisos tras incidentes o proyectos grandes
- ☐ No se realizan revisiones sistemáticas

7.4. Segregación de funciones en administración y seguridad

- ☐ Hay segregación clara entre administración de sistemas, operación de negocio y gestión de seguridad
- ☐ La segregación es parcial; algunos perfiles acumulan funciones
- ☐ La segregación es limitada o inexistente en la práctica
- ☐ No se ha analizado ni definido este aspecto

8. Métricas, ROI y mejora continua

8.1. Indicadores clave de ciberseguridad relacionados con STRIDE

- ☐ Se dispone de un cuadro de mando con indicadores que cubren explícitamente las seis categorías STRIDE
- ☐ Existen indicadores relevantes, pero no están claramente alineados con STRIDE
- ☐ Hay métricas aisladas (por ejemplo, número de vulnerabilidades), pero sin cuadro de mando coherente
- ☐ No se utilizan métricas de ciberseguridad más allá de incidentes reportados

8.2. Uso de métricas para la toma de decisiones

- ☐ Las métricas se usan regularmente en comités de dirección para priorizar inversiones y mejoras
- ☐ Se presentan métricas, pero su impacto en decisiones es limitado
- ☐ Las decisiones se toman principalmente por criterio experto o urgencias del momento
- ☐ No se utilizan métricas de forma sistemática en la toma de decisiones

8.3. Evaluación del retorno de inversión (ROI) en seguridad

- ☐ Se calculan o estiman ROI / cost-benefit de controles clave (por ejemplo, MFA, PAM, WAF, etc.)
- ☐ Se realizan estimaciones cualitativas de impacto, sin cálculo formal de ROI
- ☐ Solo se justifica inversión para cumplir requisitos regulatorios
- ☐ No se evalúa el retorno ni el impacto económico de las medidas de seguridad

8.4. Frecuencia de revisión de la postura de seguridad

- ☐ Revisión formal al menos anual, con roadmap de mejora
- ☐ Revisión formal, pero irregular o ligada a auditorías
- ☐ Revisiones ad hoc tras incidentes relevantes
- ☐ No hay revisiones formales de la postura global de seguridad

9. Comentarios finales

Este es el espacio para que exprese lo que la encuesta no le ha preguntado y debería, o para que desahogue su espíritu crítico sobre STRIDE, NIS2, la entropía digital y los presupuestos:

Comentarios adicionales:
